Cheatsheet AZ-305 — 04 · Governance: Policy, Blueprints, RBAC, management groups and tenants

1. Hierarchy and the tenant wall

```
Microsoft Entra ID tenant  ← absolute boundary: nothing crosses it
└── Root management group
    └── Management groups (up to 6 levels)
        └── Subscriptions
            └── Resource groups
                └── Resources
```

- **RBAC, Policy, Blueprints and management groups inherit downwards** and **never cross tenants**.
- "Minimum number of assignments / management groups / definitions" → **count tenants** and apply at the root MG of each one.
- Example: 2 tenants with 10 + 5 subscriptions → Network Contributor with **2 assignments** (one per root MG).
- **Resource groups** do not limit the technical association between resources (an NSG in RG2 can be associated with a subnet in RG1); they are only lifecycle, RBAC and Policy scope. The subscription and the region do limit it.
- **Tags**, not resource groups, to group by business dimension (department, cost center). A resource can only be in one RG.

2. Azure Policy: effects

Effect	What it does	New resources	Existing resources	Remediation task	Identity required
Deny	Blocks creation / update	✓ blocks	Flags as non-compliant	✗	—
Audit	Only logs non-compliance	✓ logs	✓ logs	✗	—
AuditIfNotExists	Audits if a related resource is missing	✓	✓	✗	—
Append	Adds fields / tags at creation; **denies on conflict**	✓	✗	✗	—
Modify	Adds / replaces / removes **tags and properties** of the resource	✓	✓	✓	Managed identity + **Contributor**
DeployIfNotExists (DINE)	Deploys an **ARM template** if something is missing (sub-resource, extension, diagnostic setting)	✓	✓	✓	Managed identity + deployment role
Disabled	Disables without deleting	—	—	—	—
EnforceOPAConstraint / EnforceRegoPolicy	Only the **Kubernetes/AKS** add-on (Gatekeeper/OPA, Rego)	—	—	—	—

- Tags inherited from the RG, new and existing, with remediation → **Modify**.
- Enable TDE with a template, AMA agent, diagnostic settings → **DeployIfNotExists**.
- Only at creation and without remediation → Append.
- Remediation: **managed identity** (not service principal) with the **minimum role** (Contributor for tags; never User Access Administrator, which manages RBAC).
- Evaluation: on assignment, when a resource changes and **every 24 h**; on demand only via **CLI (az policy state trigger-scan) / PowerShell / REST**, not from the portal.
- Non-compliance alerts → diagnostic setting to Log Analytics + **Log** type alert.
- Policy ≠ RBAC: Policy governs configurations; RBAC governs permissions. Policy cannot assign roles.
- Policy at management group level with **exclusions** for specific subscriptions.
- An **Initiative** groups definitions so they can be assigned together.

3. Azure Blueprints (being retired, replaced by Template Specs / Deployment Stacks)

Element	Where it is created	How many	Counted by
Management group	One per tenant (minimum)	= tenants	Tenants
Blueprint definition	In the management group (for reuse) or in a subscription	= hierarchies where it is reused	Tenants
Blueprint assignment	**Per target subscription**	= target subscriptions	Subscriptions

- Artifacts: resource groups, ARM templates, **role assignments**, policy assignments.
- Example East (Sub1, Sub2) / West (Sub3, Sub4): **2 MG · 2 definitions · 4 assignments**.
- "Minimize definitions" → define at the **root MG** of each tenant. "Assignments" → one per subscription.
- For RBAC + Policy + repeatable structure at scale → Blueprints (or Bicep + Deployment Stacks).

4. RBAC

Concept	Exam detail
Owner	Everything + manage assignments. Required to **change the directory of a subscription**
Contributor	Everything except RBAC. Enough to remediate tags, create a Recovery Services vault
Reader	Read only
User Access Administrator	Only manages RBAC
Network Contributor	Networking; apply at the root MG of each tenant
Custom roles	Define at the **management group** to reuse across all subscriptions; DataActions for the data plane (blobs, files)
Global Administrator + "Access management for Azure resources"	**Elevate access**: User Access Administrator at / ; for subscriptions with no Owner. Via PIM and revert afterwards
Site Recovery Contributor / Operator	Operate replication / run failover; neither creates the vault (that is Contributor)
Resource-context vs workspace-context (Log Analytics)	Resource-context: see only logs of the resources where you have RBAC; recommended for hub-spoke
Resource locks	CanNotDelete / ReadOnly; apply even to Owners; inherited
Resource Guard	In **another subscription/tenant**; requires a role there for critical backup operations (anti-ransomware, separation of duties)

5. Cost Management and organization

- **Tags** + Cost Management → reports per department; Policy (Modify) guarantees they exist.
- **Budgets** with alerts; **Azure Advisor** recommendations (does not act).
- **Management groups** to structure EA / divisions; **subscriptions** as billing and quota boundary.

6. Decision tree

```
What is asked?
├─ Block a configuration ..................................... Policy Deny
├─ Only detect ............................................... Policy Audit
├─ Add/fix tags or properties, new and existing ............... Policy Modify + managed identity + Contributor
├─ Deploy something missing with an ARM template ............. Policy DeployIfNotExists
├─ Governance in an AKS cluster .............................. Policy add-on (OPA/Rego)
├─ Permissions for all subscriptions with minimum effort ..... RBAC at root MG (one per tenant)
├─ Reuse a custom role across many subscriptions .............. Define at MG
├─ Repeatable package RBAC + Policy + structure .............. Blueprints (def. at MG, assignment per sub)
├─ Prevent deleting an RG even for Owners ..................... Resource lock / Policy Deny delete
├─ Subscription with no administrators after moving tenant ..... Global Admin + elevate access
├─ Move a subscription to another tenant ...................... Owner on the subscription
├─ Protect backups from compromised administrators ............. Resource Guard in another subscription
└─ Group resources by department for reporting ................ Tags (+ Policy)
```

7. Signals → answer

Wording	Answer
"minimum number of role assignments" + management groups	Number of tenants
"minimum management groups / blueprint definitions"	Number of tenants
"minimum blueprint assignments"	Number of target subscriptions
"remediation tasks" + "tags"	Modify, managed identity, Contributor
"remediation tasks" + "ARM template"	DeployIfNotExists
"trigger on-demand compliance scan"	Azure CLI / PowerShell / REST
"change the directory of a subscription"	Owner
"no accounts have permissions on the subscription"	Global Administrator (elevate access)
"create and manage the Recovery Services vault"	Contributor
"group resources by department" + "compliance reports"	Tags + Azure Policy
"ransomware" + "require a role in another subscription"	Resource Guard
"MSP manages other tenants"	Lighthouse

8. Mistakes to avoid

1. Assigning Blueprints at the management group → **assignments are per subscription**; the **definition** goes at the MG.
2. Append for existing resources → does not remediate; Modify.
3. Service principal for remediation → managed identity.
4. User Access Administrator to write tags → Contributor.
5. Believing that an MG or a role crosses tenants.

6. Reorganizing resource groups to group by department → tags.
7. Looking for the "evaluate now" button in the portal → it does not exist.